Alen Da Luz

Monitoraggio: regole e dashboard

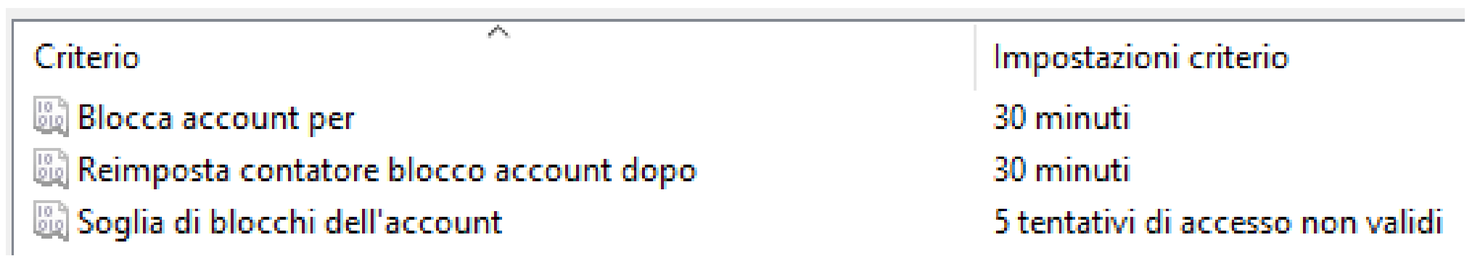
11/10/2026

DESCRIZIONE: Terzo report del progetto finale, descrive la costruzione del livello di monitoraggio in Splunk: l'abilitazione della policy di blocco account, le ricerche SPL sugli eventi di sicurezza, le regole di correlazione (alert) per brute force, blocco account e scansione delle porte, e la dashboard che raccoglie i principali indicatori. Questi strumenti vengono poi messi alla prova nella Proof of Concept del Report 4

1. Preparazione del monitoraggio

1.1 — Policy di blocco account

Per rendere rilevabili e contrastabili gli attacchi alle credenziali è stata abilitata, tramite Group Policy sul dominio, la policy di blocco account: dopo 5 tentativi di accesso non validi l'account viene bloccato per 30 minuti, questo genera l'evento 4740 (blocco account) quando un attacco brute force supera la soglia, ed è la contromisura che neutralizza l'attacco fermando l'account preso di mira



Criterio	Impostazioni criterio
Blocca account per	30 minuti
Reimposta contatore blocco account dopo	30 minuti
Soglia di blocchi dell'account	5 tentativi di accesso non validi

Fig. 1 — Criteri di blocco account configurati via GPO: soglia 5 tentativi, durata del blocco e reset del contatore a 30 minuti

1.2 — Situazione iniziale (baseline)

Prima di introdurre le regole è stata osservata la situazione normale degli accessi falliti, per distinguere il "rumore" fisiologico (pochi fallimenti occasionali) da un vero attacco, questa baseline è il riferimento rispetto al quale, nella PoC, l'impennata dei 4625 risulterà evidente

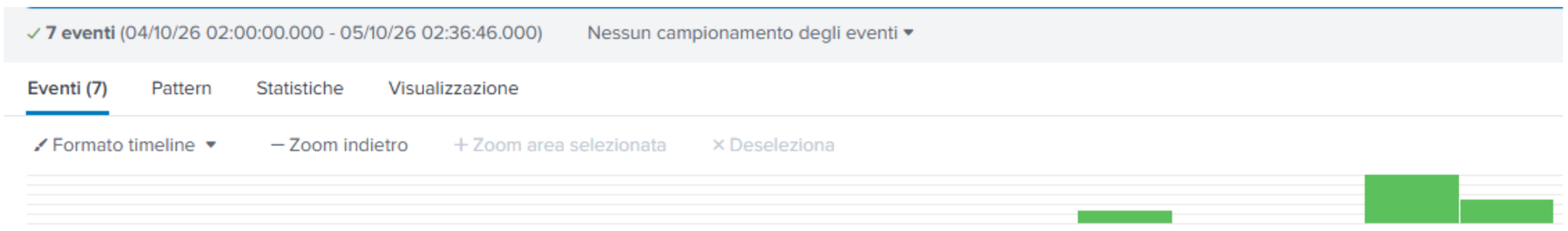


Fig. 2 — Baseline: accessi falliti registrati prima degli attacchi (pochi eventi sporadici)

2. Regole di correlazione (alert)

Le regole sono ricerche SPL salvate come alert in tempo reale: Splunk esegue continuamente la ricerca e, quando la condizione è soddisfatta, attiva l'allarme; sono state create tre regole riassunte di seguito

Regola	Evento / logica	Soglia	Scopo
Brute Force — Accessi Falliti	EventCode 4625 per host/account/IP	> 10 in breve tempo	Rileva tentativi ripetuti di accesso
Account Lockout — Blocco Account	EventCode 4740	> 0	Rileva il blocco di un account
Port Scan — Scansione Porta	Sysmon EventCode 3, molte porte da un IP	> 50 porte	Rileva scansioni di rete

2.1 — Regola Brute Force

La regola conta gli accessi falliti (4625) raggruppati per host, account bersaglio (TargetUserName) e IP sorgente (IpAddress). Quando la stessa combinazione supera la soglia in pochi minuti, l'alert scatta: è il segno di un attacco a dizionario in corso. Questa la query per la regola: index=windows source="XmlWinEventLog:Security" EventCode=4625 | stats count by host, TargetUserName, IpAddress | where count > 10

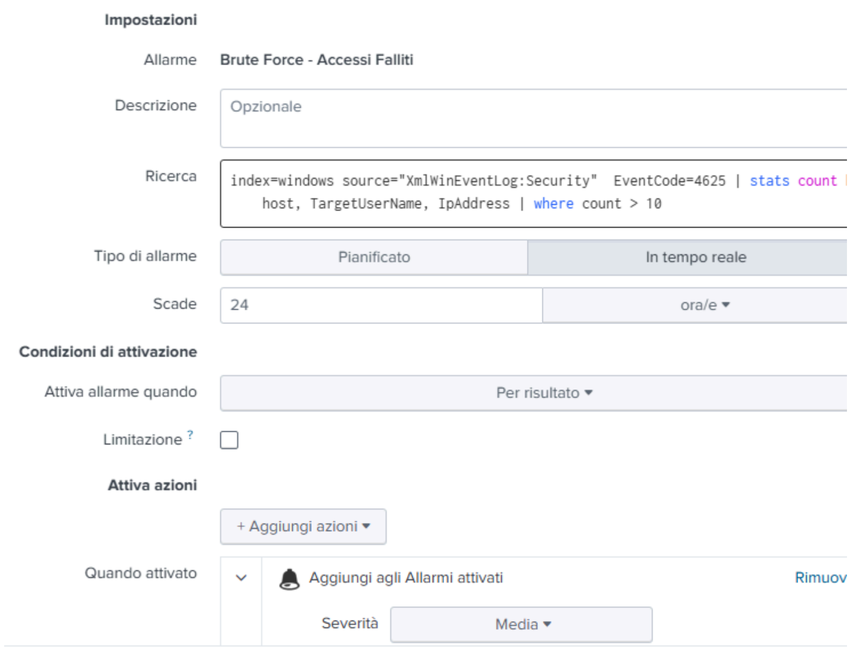


Fig. 3 — Configurazione dell'alert Brute Force: tipo "in tempo reale", attivazione al verificarsi dell'evento, azione di notifica

2.2 — Regola Account Lockout

La regola si attiva alla comparsa di un evento 4740 (account bloccato), conseguenza diretta del superamento della soglia di tentativi impostata dalla policy, questo è un segnale ad alta affidabilità: indica non solo un attacco, ma che la contromisura è intervenuta

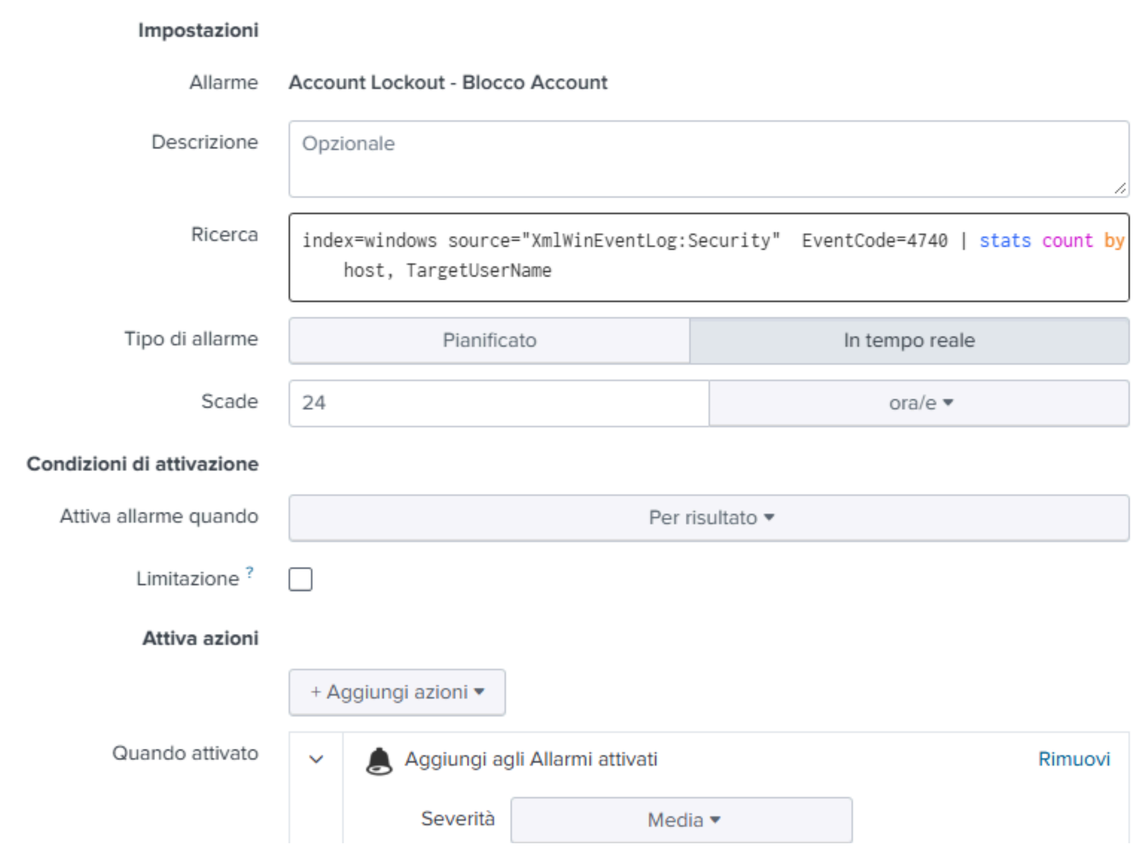


Fig. 4 — Configurazione dell'alert Account Lockout: tipo "in tempo reale", attivazione al verificarsi dell'evento, azione di notifica

2.3 — Regola Port Scan

La regola sfrutta la telemetria di rete di Sysmon (EventCode 3): conta quante porte distinte contatta ogni IP sorgente. Un singolo IP che tocca decine di porte in poco tempo è la firma di una scansione. È la prima regola di tipo "di rete", complementare a quelle basate sugli accessi.

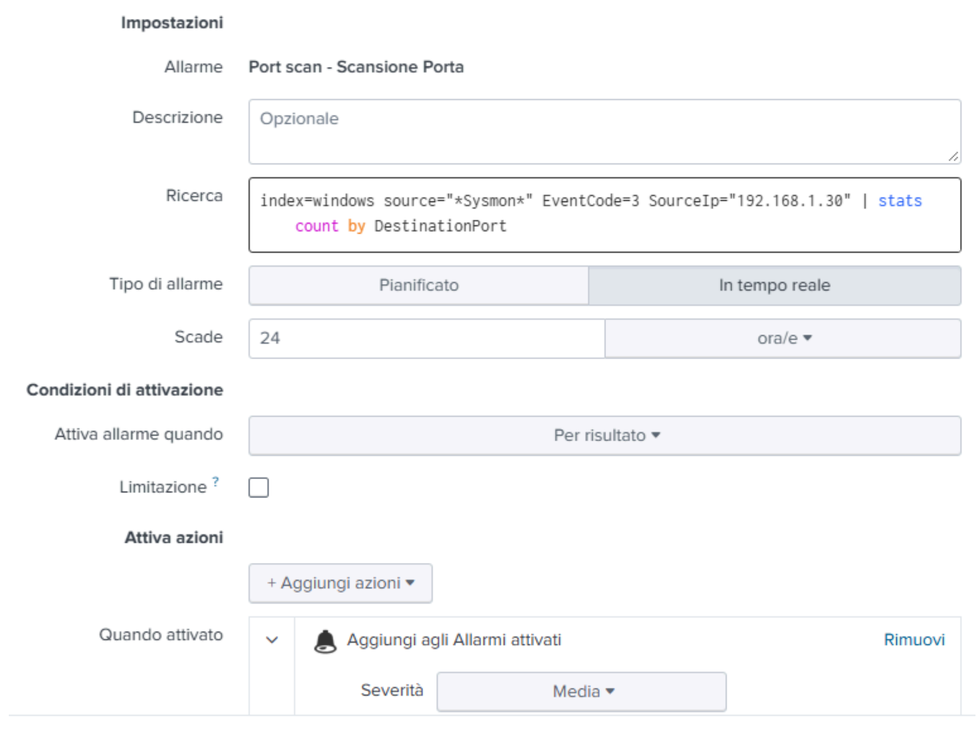


Fig. 5 — Configurazione dell'alert Port Scan: in tempo reale, con azione di notifica agli allarmi attivati

3. Dashboard di monitoraggio

È stata costruita una dashboard che raccoglie i principali indicatori di sicurezza del dominio, ogni pannello è una ricerca SPL; durante la PoC i pannelli si popolano in tempo reale evidenziando l'attacco. Di seguito la funzione di ciascun pannello

Pannello	Cosa mostra
1 — Accessi riusciti vs falliti	Andamento temporale di 4624 e 4625; un picco dei falliti segnala un attacco
2 — Account presi di mira	Conteggio 4625 per account; evidenzia quale utenza è sotto attacco
3 — IP sorgenti	Conteggio 4625 per IP; identifica la macchina attaccante
4 — Blocchi account	Account bloccati (4740) per host
5 — Totale accessi falliti	Valore cumulativo dei 4625; cresce visibilmente durante il brute force

Le immagini seguenti mostrano le ricerche SPL alla base di ciascun pannello (le visualizzazioni popolate con i dati reali dell'attacco sono riportate nel Report 4)

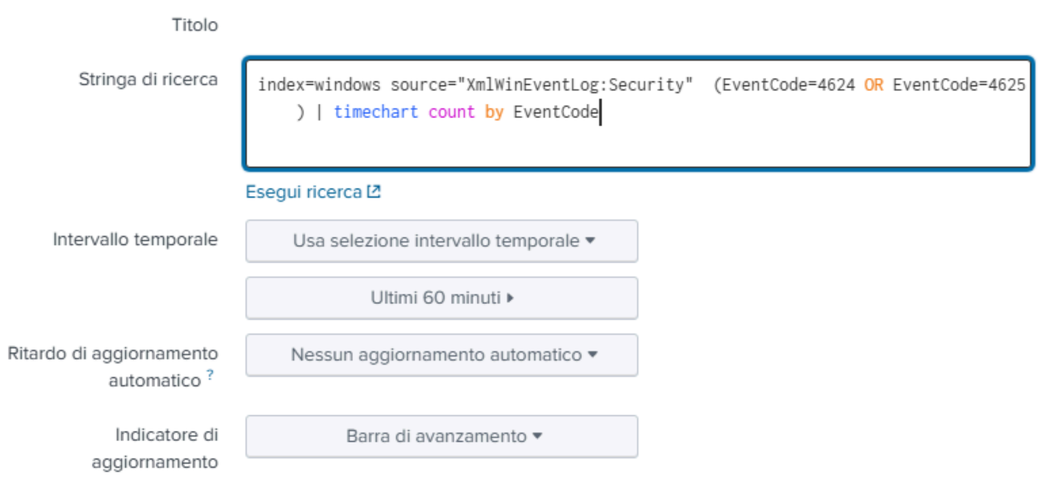


Fig. 6 — Pannello 1 — timechart degli accessi riusciti (4624) e falliti (4625)



Fig. 7 — Pannello 2 — conteggio degli accessi falliti per account (TargetUserName)

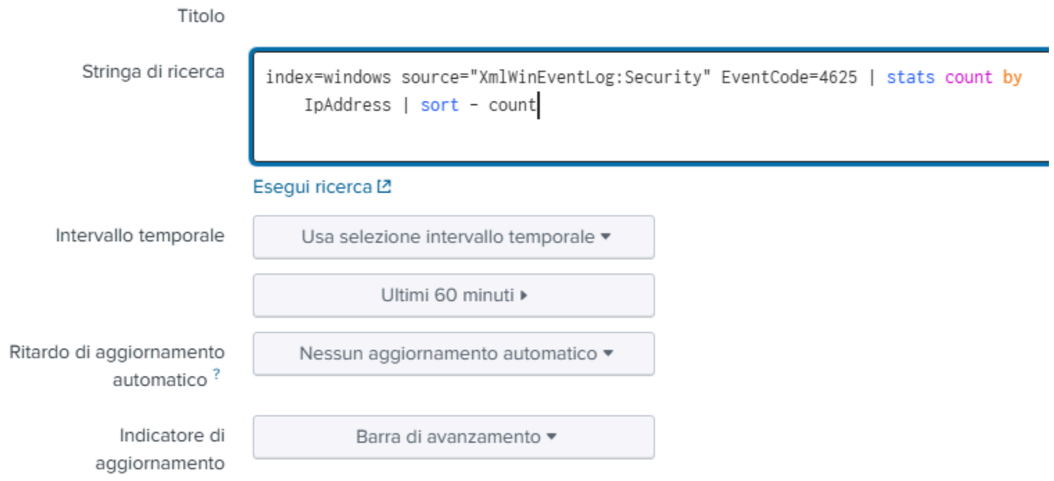


Fig. 8 — Pannello 3 — conteggio degli accessi falliti per IP sorgente (IpAddress)



Fig. 9 — Pannello 4 — blocchi account (4740) per account e host

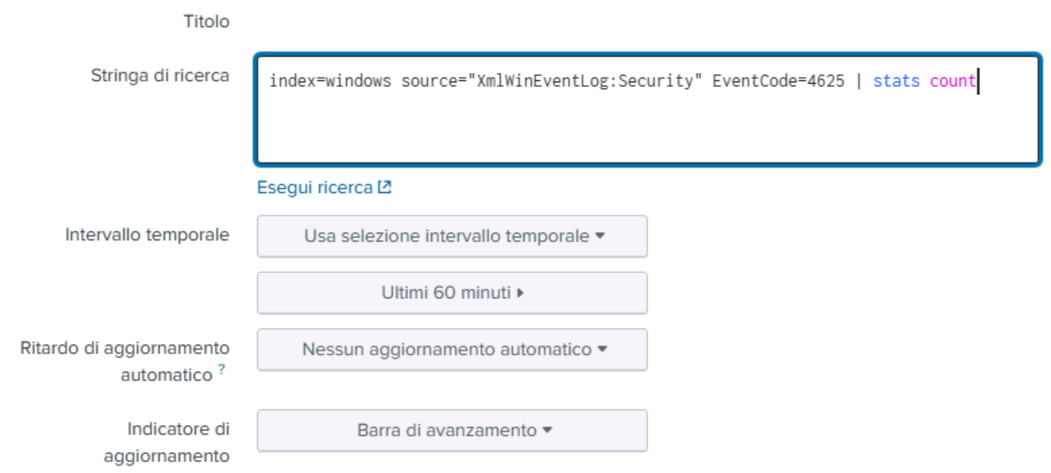


Fig. 10 — Pannello 5 — totale degli accessi falliti (valore singolo)

4. Scenari con maggiori risorse

Il livello di monitoraggio si estenderebbe così:

• Regole aggiuntive: accesso riuscito dopo molti fallimenti (brute force andato a segno, correlando 4625 e 4624 sullo stesso account), creazione di nuovi account o modifiche ai gruppi privilegiati (4720/4728), accessi fuori orario. Ogni regola si crea come ricerca SPL salvata in alert, definendo condizione e azione
• Correlazione multi-livello: con più sorgenti (rete, endpoint, IDS) si creerebbero regole che combinano eventi di natura diversa, ad esempio un port scan seguito da un brute force dallo stesso IP, aumentando l'affidabilità del rilevamento
• Dashboard e report pianificati: dashboard separate per categoria di minaccia e report periodici automatici inviati via e-mail al team di sicurezza, oltre all'eventuale adozione di Splunk Enterprise Security per il rilevamento avanzato